

PaySafe India

Access Control Policy

Governance, Risk & Compliance Portfolio Project

Document Title: Access Control Policy

Version: v1.0

Effective Date: April 2026

Document Owner: Ayush Joshi — GRC Analyst (Portfolio Project)

Policy Owner (Simulated): Chief Technology Officer, PaySafe India

Classification: CONFIDENTIAL — Internal Use Only

Next Review Date: April 2027

INDEX

Contents

Section 1 — Purpose, Scope, and Principles.	1
Section 2 — Roles and Responsibilities.	2
Section 3 — Access Provisioning and RBAC.	3
Section 4 — Authentication Standards.	4
Section 5 — Privileged Access Management.	5
Section 6 — Endpoint and Remote Access (BYOD Rules).	6
Section 7 — Monitoring, Auditing, and Review.	7
Section 8 — Enforcement and Disciplinary Action.....	8
Section 9 — Offboarding and Access Revocation.....	9

Section 1 — Purpose, Scope, and Principles.

1. **Purpose, Scope, and Principles Purpose** The purpose of this Access Control Policy is to set clear, strict rules for who is allowed to access PaySafe India's systems, data, and physical workspaces. In the past, the organization has relied on an informal, trust-based approach that prioritized daily convenience over security. This document officially ends that practice. It establishes an enforceable standard to govern exactly how access is requested, approved, monitored, and revoked, ensuring our business is protected from unauthorized access, data leaks, and human error. **Scope** This policy applies to absolutely everyone who connects to PaySafe India's network or handles its data. This includes all full-time employees, part-time staff, interns, management, contractors, and third-party vendors. It covers all physical office locations, internal software, cloud services, databases, and source code repositories. Furthermore, this policy governs any device used to access company information, applying equally to company-issued hardware and personal devices (BYOD) like home laptops or mobile phones. **Core Principles** Every rule, permission, and technical control at PaySafe India is built upon three foundational security principles:
 - **The Principle of Least Privilege:** Users will only be given the absolute minimum level of system rights necessary to perform their daily work. Extra access "just in case" is not permitted.
 - **The Need-to-Know Principle:** Access to sensitive data is granted only when an individual specifically requires that information to complete an authorized task.
 - **Individual Accountability:** Every single action taken on the company network must be traceable back to a specific, identifiable person. To guarantee this, the use of shared accounts, team logins, and shared passwords is strictly forbidden.
 - **Zero Trust (Continuous Verification):** We operate on a "never trust, always verify" model. Successfully logging in once does not grant a user permanent trust for the rest of the day. A user's identity, device health, and behavior are continuously monitored throughout their session. If the system detects increased risk or unusual activity, access can be dynamically challenged or revoked immediately, regardless of the initial login.

Section 2 — Roles and Responsibilities.

2. Roles and Responsibilities For this policy to work, access control can no longer be a shared, informal responsibility. Accountability must be clearly divided. The following roles define exactly who is responsible for every step of the access lifecycle:
 - **Policy Owner: Chief Technology Officer (CTO) / Security Lead** The CTO (or designated Security Lead) officially owns this document. They are responsible for writing, updating, and enforcing the rules within this policy to ensure they align with PaySafe India's business goals and regulatory requirements. They are the ultimate authority on how security is governed across the company.
 - **Access Approvers: Department Heads (e.g., Lead Developer, Head of HR, VP of Operations)** Department Heads act as the "System Owners" for the data under their control. They are the only people authorized to approve an access request. For example, the Lead Developer must approve any request to view source code, and the Head of HR must approve access to the payroll system. They evaluate requests based strictly on the "Need-to-Know" principle and never grant access simply as a courtesy.
 - **Technical Implementers: IT Systems Administrator** The IT Systems Administrator is responsible for putting the approved access into action. Importantly, the IT Admin does not have the authority to decide who gets access; they strictly execute the decisions made by the Department Heads. Their job is to physically create the accounts, assign the correct role-based permissions, configure Multi-Factor Authentication (MFA), and ensure the technical setup perfectly matches the approved request.
 - **Responsible Users: All Employees, Interns, and Contractors** Every individual given a PaySafe India login is responsible for following the rules. This means keeping passwords entirely private, never sharing login credentials with a coworker, locking devices when stepping away, and immediately reporting any suspicious activity or unauthorized access to the IT Administrator. End-users are the first line of defense in keeping the system secure.

Section 3 — Access Provisioning and RBAC.

3. Access Provisioning and RBAC (Role-Based Access Control) The Access Provisioning Process To eliminate the habit of simply sharing passwords or copying someone else's permissions, granting access to a new employee now follows a strict, step-by-step sequence. First, HR finalizes the employment contract and sends a formal notification to the IT Administrator and the new hire's Department Head. Second, the Department Head submits an official access request to IT that specifies the employee's exact job title and corresponding predefined role; we no longer accept vague requests like "give them the same access as John." Third, IT creates a completely unique, individualized account for the new hire, ensuring no shared or team credentials are used. Finally, before any actual data can be viewed, IT configures the account to enforce mandatory Multi-Factor Authentication (MFA) upon the user's very first login on day one. Baseline RBAC Structure To enforce the "Need-to-Know" principle, an employee's access is determined solely by their job function, not their seniority or personal requests. Below is the baseline Role-Based Access Control (RBAC) mapping for key departments at PaySafe India:
 - Customer Support Representative: Granted access to the customer service ticketing platform and read-only access to the user transaction dashboard to assist customers with payment inquiries. They are strictly blocked from accessing the underlying transaction database, company financial records, or any software code.
 - Software Engineer: Granted read and write access to development tools, the source code repository, and staging environments to build and test application features. They are explicitly denied access to live production databases, real customer financial data, and HR administrative systems.
 - Human Resources Manager: Granted access to employee personnel files, recruiting platforms, and the payroll processing system. Because their role is entirely non-technical, they have absolutely zero access to the company's source code, IT administrative tools, or the payment transaction network.

Section 4 — Authentication Standards.

4. **Authentication Standards** To protect our systems from unauthorized entry and credential theft, relying solely on a username and password is no longer acceptable. All personnel must adhere to the following authentication standards: **Mandatory Multi-Factor Authentication (MFA)** Multi-Factor Authentication (MFA) is strictly mandatory for every single user—from interns to the CEO—across all company applications, databases, and network portals. There are zero exceptions to this rule. A login attempt will only be successful if the user provides their password (something they know) alongside a secondary verification, such as a time-based code from an approved authenticator app on their mobile device (something they have). **Password Requirements** To eliminate the risk of easily guessed or reused passwords, all employee credentials must meet the following strict criteria:
 - **Length and Complexity:** Passwords must be a minimum of 12 characters long and include a mix of uppercase letters, lowercase letters, numbers, and special symbols.
 - **Zero Reuse:** You are strictly forbidden from using the same password across multiple internal systems. The password you use for your email cannot be the same password you use for the HR portal or the transaction database.
 - **Password Managers:** To make compliance easy, the company will provide an enterprise password manager. Employees are required to use this tool to generate and store unique, complex passwords for every individual account. **Additional Requirements for Privileged Accounts** Standard MFA is not enough for accounts that hold administrative power, such as those used by the CTO or IT Administrator. Because these accounts can alter system infrastructure, they are subject to additional Privileged Access Management (PAM) controls:
 - **Credential Vaulting:** High-level administrative passwords will be stored in a secure digital vault. Administrators will check these credentials out when needed, meaning they will not manually create, know, or memorize the root passwords.
 - **Just-In-Time (JIT) Access:** Privileged users will not maintain permanent, "always-on" administrative rights. Instead, they will operate day-to-day with a standard user account. When they need to perform an administrative task, they must request temporary, time-bound access that automatically expires and revokes their power once the task is complete.

Section 5 — Privileged Access Management.

5. **Privileged Access Management (PAM)** While standard user accounts have limited permissions, privileged accounts (such as IT Administrator or Root accounts) have the power to alter the company's entire technological infrastructure. Because of this high risk, the entire lifecycle of a privileged account is governed by strict, independent oversight. **Creation and Approval of Privileged Accounts** To prevent a conflict of interest and enforce the separation of duties, an IT Administrator cannot approve or create an administrative account for themselves or their peers independently. Any request for a new privileged account—or temporary elevation of an existing account—must be formally submitted and explicitly approved in writing by the Chief Technology Officer (CTO). Only after the CTO signs off can the IT department technically provision the access. **Active Session Monitoring and Logging** When a user is actively operating within a privileged session, they are subject to continuous monitoring. Every action taken during an elevated session—including commands executed, files accessed, and system configurations changed—is automatically recorded in a secure, centralized audit log. To guarantee the integrity of these records, privileged users are technically restricted from modifying, pausing, or deleting the audit logs of their own sessions. **Mandatory Access Reviews** Privileged access is never granted indefinitely. To prevent "privilege creep," the CTO, working alongside the IT Administrator, will conduct a mandatory, formal review of all active privileged accounts every 30 days. During this monthly audit, they must verify that every elevated account is still actively required for the user's current job function. Any privileged access that is no longer necessary will be immediately revoked and downgraded to standard user access.

Section 6 — Endpoint and Remote Access (BYOD Rules).

6. Endpoint and Remote Access (BYOD Rules) PaySafe India supports a flexible working environment, allowing employees to use personal devices (Bring Your Own Device - BYOD) alongside company-issued hardware. However, because these devices access sensitive financial systems and customer data, they are subject to strict security requirements before they are allowed to connect to the network. Mandatory Device Requirements Before any device—whether a personal mobile phone, home laptop, or company-issued computer—is permitted to access PaySafe India applications, emails, or data, it must meet the following baseline security standards:

- The device must be running a currently supported operating system with the latest security patches installed.
- Full-disk encryption (such as BitLocker for Windows or FileVault for Mac) must be actively turned on to protect data if the physical device is stolen.
- A strong screen lock (complex PIN, password, or biometric like FaceID) set to automatically lock the screen after five minutes of inactivity. Mandatory Security Software Trust is not a security control. To guarantee that the mandatory device requirements are actually being met, every device used for work must be enrolled in PaySafe India's Mobile Device Management (MDM) software. Network access will be automatically blocked for any device that does not have the MDM profile installed and active. The MDM allows the IT Administrator to verify that encryption is on and the OS is updated before granting access to company portals. Lost, Stolen, or Compromised Devices By choosing to use a personal device to access PaySafe India's systems, employees explicitly agree to our data protection protocols. If a device containing company data is lost, stolen, or suspected to be compromised, the employee must report it to the IT Administrator immediately. In these scenarios, PaySafe India reserves the right to use the MDM software to remotely wipe all corporate data, applications, and saved credentials from the device to prevent a data breach.

Section 7 — Monitoring, Auditing, and Review.

7. **Monitoring, Auditing, and Review** Creating access rules is only half the job; we must also actively prove that these rules are being followed. To guarantee the integrity of our systems and detect unauthorized activity, PaySafe India maintains a strict monitoring and auditing schedule. **Continuous Real-Time Monitoring** To ensure individual accountability, system access is continuously monitored in real-time. The IT Administrator is responsible for configuring automated audit logs across all critical infrastructure, including cloud platforms, the transaction database, and source code repositories. These logs automatically record exactly who logs in, when they log in, where they are logging in from, and what data they interact with. Any suspicious activity—such as repeated failed login attempts or an employee trying to access a system outside their designated role—will trigger an immediate alert to the IT department for investigation. **Standard User Access Reviews** Over time, employees change roles or take on temporary projects, which often leads to them collecting access rights they no longer need (known as "privilege creep"). While privileged administrative accounts are reviewed monthly, standard employee access is formally audited on a quarterly basis (every 90 days). During this review, IT will provide each Department Head with a list of their team members and their active permissions. The Department Head must explicitly confirm that each employee still requires that exact access for their current daily work. If not, the unnecessary access is immediately revoked. **Annual Policy Review** As PaySafe India grows, adopts new software, and faces new security threats, the rules governing access must adapt. The Chief Technology Officer (CTO) and the designated Security Lead will conduct a comprehensive review of this entire Access Control Policy at least once every 12 months. Furthermore, an immediate review and update of this document will be triggered if the company undergoes a major infrastructure change or experiences a security incident.

Section 8 — Enforcement and Disciplinary Action.

8. Enforcement and Disciplinary Action Rules without consequences are just suggestions. This section ensures that the technical guidelines established in this Access Control Policy are strictly enforced, protecting PaySafe India's data, intellectual property, and customer trust. Accidental vs. Deliberate Violations We recognize the difference between an honest mistake and intentional negligence. Disciplinary actions are scaled based on the intent and severity of the violation:

- **Accidental Violations:** If an employee makes a genuine mistake—such as falling for a sophisticated phishing email or accidentally leaving a laptop unlocked in the office—the focus is on correction. Consequences typically include mandatory security retraining, a formal written warning, and a temporary lock on their account until the system is secured.
 - **Deliberate Violations:** Willfully bypassing security protocols is a serious offense. Actions like intentionally sharing your password with a coworker, actively refusing to install the required MDM on your work device, or purposefully dodging MFA prompts will result in immediate formal HR disciplinary action, which may include unpaid suspension or termination.
 - **Zero-Tolerance Offenses (Immediate Termination)** Certain actions pose such a severe, existential risk to the company that they will result in immediate termination of employment, with no prior warnings or second chances. These include:
 - Using access privileges to view, alter, or delete customer financial transaction records without a verified, documented business requirement.
 - Unauthorized downloading, copying, or exfiltrating of the company's proprietary source code, databases, or customer lists to personal storage or external emails.
 - Intentionally creating unauthorized "backdoor" accounts, disabling audit logs, or sharing high-level administrative credentials.
- Legal Recourse** As a financial technology company, PaySafe India handles sensitive data protected by law. Therefore, consequences are not limited to internal HR actions. In the event of intentional data theft, intellectual property theft (such as stealing source code), or deliberate system sabotage, PaySafe India reserves the right to pursue civil litigation to recover financial damages. Furthermore, the company will immediately hand over all internal audit logs to law enforcement and regulatory authorities for criminal prosecution.

Section 9 — Offboarding and Access Revocation.

9. Offboarding and Access Revocation Removing access when it is no longer needed is just as critical as securing it in the first place. To protect PaySafe India from disgruntled ex-employees, competitor espionage, and internal "privilege creep," access revocation is handled immediately and according to strict timelines based on the nature of the departure. Involuntary Termination (Fired or Laid Off) When an employee or contractor is terminated involuntarily, the risk of data sabotage or theft is at its highest.
- Timeline: Access revocation is immediate and simultaneous. HR must notify the IT Administrator before the termination meeting begins.
 - Procedure: The moment the meeting starts, IT will instantly disable all network access, lock the user's email, and terminate all active sessions. If the user has company data on a personal device (BYOD), the IT Administrator will immediately trigger the Mobile Device Management (MDM) software to remotely wipe the corporate data partition.
 - Voluntary Resignation (Working a Notice Period) When an employee resigns on good terms and works a notice period, they still need access to complete their daily tasks and hand over projects, but their risk profile changes.
 - Timeline: Complete access revocation occurs exactly at 5:00 PM (or end of shift) on their final official working day.
 - Procedure: During the notice period, the employee's account is flagged for heightened monitoring. Department Heads reserve the right to immediately revoke highly sensitive privileges—such as access to the production transaction database or source code repositories—during the notice period to prevent intellectual property from leaving with the employee. All company-issued hardware and physical access keys must be surrendered on the final day.
 - Role Change (Internal Transfer or Promotion) When an employee moves to a new department or gets promoted, they do not get to keep their old permissions. This is the primary cause of "privilege creep," where a user slowly accumulates unnecessary access over time.
 - Timeline: Revocation of old access and provisioning of new access happens simultaneously on the official start date of the new role.
 - Procedure: Access is not cumulative. The employee's previous role profile is entirely wiped, and they are issued a fresh set of permissions based strictly on the Role-Based Access Control (RBAC) requirements of their new job title. If they need temporary access to their old systems to help train their replacement, it must be formally requested and granted as temporary, time-bound access.